

ShieldScan — Complete Project Guide & Interview Manual

Author: Harshit Kumar | **Topic:** Explainable ML Cybersecurity System | **Model:** Calibrated Linear SVM

1. Executive Summary (The 30-Second Pitch)

*ShieldScan is an explainable machine-learning cybersecurity system that detects Cross-Site Scripting (XSS) attacks in real time. Instead of relying on brittle regex rules or slow cloud AI APIs, ShieldScan uses a local **Calibrated Linear SVM model** combined with 3,000 character-level *n*-grams and 18 handcrafted security features. It screens payloads in sub-millisecond time (~0.005 ms) with **99.80% recall** and an exceptionally low **0.20% false-negative rate**, providing human-readable explanations, safe decoding, and OWASP remediation guidelines.*

2. Motivation & The Real-World Problem

What is Cross-Site Scripting (XSS)?

Cross-Site Scripting is a critical web application vulnerability (OWASP Top 10) where attackers inject malicious JavaScript into web applications. When executed in victim browsers, it leads to session hijacking (cookie theft), credential theft via fake modals, malicious redirections, and unauthorized transactions.

Why Traditional Defenses Fail:

- **Brittle Regex Filters:** Easily bypassed with character encoding (%3Cscript%3E), inline event handlers (onerror=), or Unicode escapes (\u003Cscript\u003E).
- **Black-Box Machine Learning:** Typical ML classifiers only return a number without explaining what rule triggered or how to fix it.
- **Cloud AI Privacy Risks:** Sending internal web traffic and customer logs to external LLMs (like ChatGPT) violates enterprise data privacy laws (GDPR, HIPAA).

3. Machine Learning Architecture (How It Works)

ShieldScan processes untrusted strings through a dual feature extraction pipeline feeding into a Calibrated Linear SVM:

1. **Safe In-Memory Canonicalization:** Decodes URL, HTML entities, and Unicode escapes in memory without executing HTML.
2. **Character TF-IDF (2–5 N-grams):** Extracts 3,000 sub-word character patterns to capture malformed syntax and structural anomalies.
3. **18 Handcrafted Security Features:** Regex indicators detecting dangerous JavaScript primitives (script tags, onerror, alert, eval, document.cookie, iframe, data: URIs, vbscript).
4. **Calibrated Linear SVM:** Outputs true mathematical probabilities (0.0 to 1.0) via Platt Scaling for threshold-based severity classification (SAFE, LOW, MEDIUM, HIGH, CRITICAL).

4. Model Selection & Held-Out Benchmark

In cybersecurity screening, **False-Negative Rate (FNR)** is the primary metric because a missed attack executes malicious code in user browsers. Evaluated on a held-out 80/20 test split (11,259 samples):

Candidate Model	Accuracy	F1 Score	Recall	False-Negative Rate	Latency / payload
Logistic Regression	99.33%	99.51%	99.22%	0.78%	0.001 ms
Random Forest	99.69%	99.77%	99.67%	0.33%	0.050 ms
Calibrated Linear SVM (Selected)	99.73%	99.80%	99.80%	0.20% (Lowest Misses)	0.005 ms (10x faster)

5. Technology Stack & Technical Justification

Component	Technology	Why This Specific Tool?
ML Core	Scikit-learn & NumPy	Industry-standard classical ML; high-speed sparse matrix multiplication.
Model Persistence	Joblib	Efficient serialization for scikit-learn models with zero disk bloat.
API Backend	FastAPI & Pydantic	Sub-millisecond async performance, automatic Swagger docs, strict schema validation.
Rate Limiting	SlowAPI	Protects API endpoints against denial-of-service and brute-force scans.
Frontend UI	React 18 & Vite	Instant HMR development, modern component tree, and sub-second production builds.
CSS Framework	Tailwind CSS	Utility-first design system with dark/light theme support and zero runtime overhead.

6. Local Machine Learning vs. Generative AI Advisory

Local ML (Primary Engine): Fast (~0.005 ms), 100% deterministic, privacy-preserving, and mathematically calculates probabilities.

Generative AI (Advisory Layer): Slower (1.5-3.0s), non-deterministic, but provides natural language AppSec advice, OWASP code review, and comparative triage.

7. Top Interview Questions & Winning Defense Answers

Q1: Walk me through what ShieldScan does.

Defense Answer: "ShieldScan is an explainable XSS detection system. It extracts 3,000 character TF-IDF n-grams and 18 handcrafted security features, which feed into a Calibrated Linear SVM. In ~0.005 ms, it classifies the payload with 99.80% recall and outputs exact probabilities, severity tiers, attack categories, and OWASP code fixes."

Q2: Why not just use an LLM or ChatGPT to detect XSS?

Defense Answer: "LLMs are 1,000x slower (seconds vs. microseconds), non-deterministic, expensive, and present customer data privacy risks. ShieldScan uses local ML as the authoritative detector and keeps LLMs as an optional advisory second opinion."

Q3: Why choose Calibrated Linear SVM over Random Forest?

Defense Answer: "In cybersecurity, missed attacks (False Negatives) are critical. Calibrated Linear SVM achieved a 0.20% False-Negative Rate (a 39% reduction vs. Random Forest's 0.33%), while executing 10x faster (~0.005 ms). Platt Scaling calibration allows true probability output."

Q4: Can this ML model replace standard sanitization and output encoding?

Defense Answer: "No. ML is a pre-execution screening/triage layer (defense-in-depth). Complete application security requires contextual output encoding, strict DOMPurify sanitization, and Content Security Policy (CSP) headers at the rendering layer."